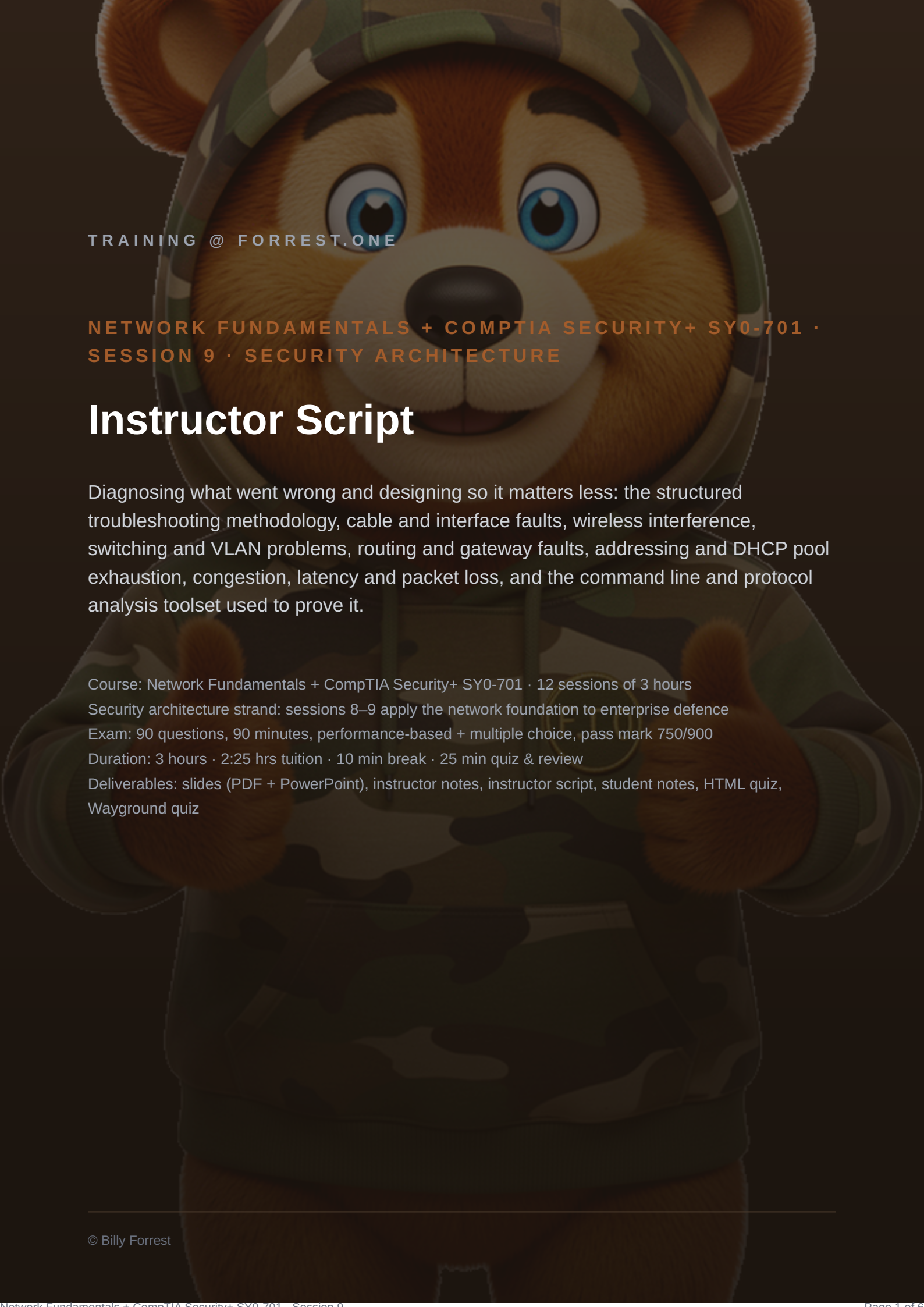




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 9 · SECURITY ARCHITECTURE

Instructor Script

Diagnosing what went wrong and designing so it matters less: the structured troubleshooting methodology, cable and interface faults, wireless interference, switching and VLAN problems, routing and gateway faults, addressing and DHCP pool exhaustion, congestion, latency and packet loss, and the command line and protocol analysis toolset used to prove it.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

Security architecture strand: sessions 8–9 apply the network foundation to enterprise defence

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Instructor Script — Endpoint, Application, Cloud & Virtualisation Security

A word-for-word delivery script for Session 9. Stage directions appear in square brackets. Each slide runs roughly 45–90 seconds of speech; activities and discussions expand the timings in the instructor notes.

Slide 1 · Title

Welcome to Session 9: Endpoint, Application, Cloud and Virtualisation Security. Session 8 secured the network boundary. Today we defend the assets themselves: the hosts, the code they run, and the cloud and virtualised estate that hosts so much of it. Asset first: for every asset, name the control.

Slide 2 · Defence beyond the network

A quick orientation. Session 8 gave us the appliances and protocols at the boundary. Today: endpoint protection and management, the application lifecycle and secure coding, application-layer attacks, and cloud and virtualisation security. The thread: every layer needs its own controls. The exam line: pick the control for the asset.

Slide 3 · Session objectives

By the end of these three hours you will be able to explain endpoint protection, covering hardening, EDR and application control; describe mobile device management and mobile threats; secure the SDLC with DevSecOps and secure coding; describe the application attacks, including injection, XSS and CSRF; explain cloud security with the service models and shared responsibility; and secure virtualisation. The quiz tests every one.

Slide 4 · Endpoint protection

The endpoint is any device that touches the network, whatever its role: laptop, phone, server, sensor. The protection stack has five parts: antivirus and EDR, signature detection plus behaviour monitoring; a host firewall; hardening; patching; and application control. The gap: signatures only name what they have already seen, so unknown threats slip through. Behaviour monitoring watches what a process does, not what it is called, which catches what signatures cannot name.

Slide 5 · Hardening the endpoint

Hardening starts with a baseline, a documented secure configuration that puts the system in a known secure state. You can build that baseline from CIS benchmarks and vendor hardening guides. Patch management closes the known holes first, then you verify the fix. Disable what you do not use: services, ports and default accounts, all of which reduce the attack surface. And the test: would a default install fail your policy? If it would pass, you are not hardened.

Slide 6 · Application control

Two approaches to controlling what runs. Allowlisting: only pre-approved software runs. Blocklisting: known bad software is denied. A supporting control is code signing, which verifies the origin and integrity of software before it executes, so a tampered binary is rejected. The modern choice is allowlisting, because blocklists miss the unknowns, and malware cannot execute if it is not approved in the first place.

Slide 7 · Mobile device management

MDM enrolls, configures, enforces and can wipe devices centrally. BYOD brings personal devices carrying corporate data, so you vet the applications before they install and answer with containers: work and personal data separated on the device. Controls: remote wipe, encryption and jailbreak detection. The device is managed, never blindly trusted. Weigh BYOD against corporate-owned devices; the latter give more control over configuration and compliance.

Slide 8 · Activity: secure the fleet

[Run the activity per the instructor notes. 6 minutes pairs, 4 minutes debrief.] A laptop runs an unknown executable: allowlisting stops it. A manager's phone holds corporate mail: MDM with containers fits BYOD. Which device never joins the domain? Guest and IoT devices stay off. And the one control every endpoint needs: patching, the baseline.

Slide 9 · Operating system security

The OS layer. User accounts: least privilege, no admin by default. Secure boot: a verified boot chain that blocks tampered firmware from loading at startup. Full disk encryption: data at rest stays unreadable if the drive walks away. Firmware updates close vulnerabilities below the operating system, which candidates often overlook. And the habit: update, reboot, verify.

Slide 10 · Discussion

[Run the discussion per the instructor notes.] Your AV never fired, yet a workstation was compromised. What went wrong? Signatures miss unknown threats. Behaviour monitoring, allowlisting and patching would have caught it or prevented it. Detection is a stack, not a single product; layer the controls.

Slide 11 · Break

Ten minutes. When we return: the application lifecycle, secure coding and the attacks that break applications.

Slide 12 · Security in the SDLC

Shift left: security from the first design, not the last test. Threat modelling finds the attack surface before code exists. Code review, human and automated, happens at every change. Secure coding adds least privilege for the code itself, error handling that leaks nothing, and input validation using whitelisting, sanitisation and boundary checks. And testing: SAST for the source, DAST for the running application. The later you find a flaw, the more it costs.

Slide 13 · DevSecOps

DevSecOps makes security part of the pipeline, not a gate at the end. In CI/CD, every build is scanned and tested automatically. Infrastructure as code is in scope too: scan your templates and manage secrets centrally rather than leaving keys in configuration files. The failure mode is security bolted on at release. The outcome: secure code ships as fast as insecure code, because the checks run continuously.

Slide 14 · SQL injection

The classic application attack. The flaw: user input is treated as part of the query. The impact: an attacker reads, modifies or deletes database data. The classic fix: parameterised queries, so input is data and never code. Back that with input validation on every field: whitelist, sanitise and bound the input. And the test mindset: any input field is a potential injection point.

Slide 15 · XSS and CSRF

Two attacks, two targets. Cross-site scripting: attacker script runs in another user's browser. Cross-site request forgery: a forged request rides a victim's session. The fixes: output encoding, same-site cookies and tokens. A Web Application Firewall adds defence by filtering and monitoring web traffic. The difference: XSS hijacks the browser; CSRF hijacks the action.

Slide 16 · More application attacks

Three more. Buffer overflow: excess input overwrites memory. Directory traversal: dot dot slash escapes the web root. Race condition: a timing gap between check and use. Add sandboxing: isolate risky code so a compromise is contained rather than reaching the whole system. The pattern across all of them: input validation and least privilege.

Slide 17 · Activity: find the flaw

[Run the activity per the instructor notes.] A login field accepts quote-space-OR-one-equals-one: that is SQL injection. A script tag appears in another user's browser: XSS. A forged form submission uses a logged-in session: CSRF. And the two fixes that cover most of these: parameterised queries and output encoding.

Slide 18 · Cloud deployment and service models

The cloud models. IaaS: virtual machines, storage and network, so you secure everything above the hypervisor. PaaS: the platform is provided, so you secure the application and its data. SaaS: the software is delivered, so the vendor secures nearly everything. Then the deployment models: public, private, hybrid and community, which tell you who owns and operates the infrastructure, and each shifts the shared responsibility line in a slightly different way.

Slide 19 · Shared responsibility

The exam core. The vendor secures the cloud, the infrastructure underneath. The customer secures what is in the cloud: configuration, data, access. The line moves: with IaaS you secure the guest; with SaaS the vendor does more. Deployment models matter too, in a community cloud responsibilities are shared among the member organisations and the provider. Misunderstanding the line is a failing answer, so know where it falls for each model.

Slide 20 · Misconfiguration is the number one cloud risk

Not exotic attacks, but misconfiguration. Defaults left in place, storage buckets left open, policies too permissive. The exposure: data leaks reachable from the internet. The tooling: CASB, cloud security posture management and policy as code. With infrastructure as code, scan your templates and check compliance automatically before anything is deployed. And the habit: assume misconfiguration until proven otherwise.

Slide 21 · Securing the virtual estate

Virtualisation changes the attack surface. The hypervisor separates the virtual machines, so attack it and you own everything on it. Hypervisor types matter: a bare-metal Type 1 hypervisor has a smaller attack surface than a hosted Type 2 that depends on an operating system. VM escape: breaking out of the guest into the host. Containers share the kernel, so isolation needs namespaces and seccomp. The controls: patch the hypervisor, least privilege, network isolation.

Slide 22 · Quiz

[Direct candidates to [Quiz_Session_09.html](#). 15 minutes.] Open the session quiz. Twenty questions, immediate feedback, and every question is tagged with its topic area: you will see the tag, like 9C Application

Attacks, above each question. Read every explanation; the distractors teach as much as the answers. Aim for seventy percent or better. The Wayground version is available for in-class assessment.

Slide 23 · Key takeaways

Five takeaways. One: endpoints need a stack, AV/EDR, hardening, patching, app control. Two: mobile is managed, not trusted, MDM, containers, remote wipe. Three: secure code shifts left, threat modelling, review, SAST and DAST in the pipeline. Four: injection is input as code, parameterised queries and output encoding. Five: cloud is shared responsibility, you secure what is in the cloud, never assume.

Slide 24 · Revision checklist

Before next session: retake the quiz until you score seventy percent without guessing. Audit an application: find one input field and its validation. Map the responsibility line for a SaaS and an IaaS you use. And read ahead to Session 10: vulnerability management, resiliency and asset protection.

Slide 25 · Next session preview

Next time, Vulnerability Management, Resiliency and Asset Protection. We find the holes: scanning, CVSS, prioritisation. We fix them: patching, compensating controls, disclosure. And we survive what gets through: backups, redundancy and site security. See you there.